Unit IV
Cyber Forensics and Auditing

CYBER FORENSIC

It is investigating, gathering, and analysing information from a computer device which can then be transformed into hardware proof to be presented in the court regarding the crime in question. A very important aspect of the investigation is making a digital copy of the storage cell of the computer and further analysing it so that the device itself doesn't get violated accidentally during the whole process. It finds its application mainly in fighting vicious online crimes like hacking and DOS – denial of service attacks. The above-mentioned proof that gives the upper hand to the investigators in any crime scene even remotely involving a computer device can be in the form of browsing history, email logs, or any other digital footprint of the criminal.

Role of forensics Investigator

The role of a forensic computer analyst is to investigate criminal incidents and data breaches. These forensic analysts often work for the police, law enforcement agencies, government, private, or other forensic companies. They use specialized tools and techniques to retrieve, analyze, and store data linked to criminal activity like a breach, fraud, network intrusions, illegal usage, unauthorized access, or terrorist communication.

Employers look for certified forensic investigators with key digital forensic skills, including: are as follows:

- Defeating anti-forensic techniques
- Understanding hard disks and file systems
- Operating system forensics
- Cloud forensic in a cloud environment
- Investigating email crimes
- Mobile device forensics

A Computer Forensics Investigator or Forensic Analyst is a specially trained professional who works with law enforcement agencies, as well as private firms, to retrieve information from computers and other types of data storage devices. Equipment can often be damaged either externally or internally corrupted by hacking or viruses. The Forensic Analyst is most well-known for working within the law enforcement industry; however, he or she can also be tasked to test the security of a private company's information systems. The Analyst should have an excellent working knowledge of all aspects of the computer including but not limited to hard drives, networking, and encryption. Patience and the willingness to work long hours are qualities that are well-suited for this position.
During criminal investigations, an Analyst recovers and examines data from computers and other electronic storage devices in order to use the data as evidence in criminal prosecutions. When equipment is damaged, the Analyst must dismantle and rebuild the system in order to recover lost data. Following data retrieval, the Analyst writes up technical reports detailing

how the computer evidence was discovered and all of the steps taken during the retrieval process. The Analyst also gives testimony in court regarding the evidence he or she collected. The Analyst keeps current on new methodologies and forensic technology, and trains law enforcement officers on proper procedure with regard to computer evidence.

Forensics Investigation Process

For those working in the field, there are five critical steps in computer forensics, all of which contribute to a thorough and revealing investigation.

- Policy and Procedure Development.
- Evidence Assessment.
- Evidence Acquisition.
- Evidence Examination.
- Documenting and Reporting.

This model was the base fundament of further enhancement since it was very consistent and standardized, the phases namely: Identification, Preservation, Collection, Examination, Analysis and Presentation (then a pseudo additional step: Decision). Each phase consists of some candidate techniques or methods.

There are 7 steps in identifying analysis at a forensic case:

- secure the scene.
- separate the witnesses.
- scan the scene.
- seeing the scene (taking photographs)
- sketch the scene.
- search for evidence.
- secure the collected evidence.

➢ How long does a forensic investigation take?

15 to 35 hours

➢ How many steps are there in digital forensics?

three steps

➢ What are the types of evidence at a crime scene?

Real evidence;
Demonstrative evidence;
Documentary evidence; and.
Testimonial evidence.

Collecting Network based Evidence

Network based evidence is also useful when examining host evidence as it provides a second source of event corroboration which is extremely useful in determining the root cause of an incident. The ability to acquire network-based evidence is largely dependent on the preparations that are untaken by an organization prior to an incident. Without some critical components of a proper infrastructure security program, key pieces of evidence will not be

available for incident responders in a timely manner. The result is that evidence may be lost as the CSIRT members hunt down critical pieces of information. In terms of preparation, organizations can aid the CSIRT by having proper network documentation, up to date configurations of network devices and a central log management solution in place.

Network Forensics is the process of capturing, recording and conducting analysis of the various network events in order to identify the origin of the security attacks and other problems. This helps in figuring out the unauthorized access to the computer system and conducts search for the evidence in such occurrences. Network Forensics has the capability to conduct investigation at a network level as well as the events that take place across an IT system.

Intrusion detection,
logging and
correlating intrusion detection and logging

Network-based digital evidence is a type of digital evidence which arises as product of the communications over a network. The primary and the secondary storage media of computers (such as the RAM and hard drives) tend to be productive elements for the forensic analysis and investigation. As a result of all the fragments of data, constant storage can maintain forensically recoverable and appropriate evidence for hours, days and years beyond the file deletion and storage reuse. Network-based digital evidence can be exceedingly unpredictable in variance to this. Within the milliseconds of the blinking of an eye, the packets move swiftly and lightly across the wire and disappear from the switches. Web sites keep changing from when and where they're viewed.

Challenges relating to Networked-based Digital Evidence

Network-based evidences lays down certain specific and prominent challenges in various areas, some of the most common challenges which are related to the Network-based digital evidence are as follow:

Acquisition: To find or locate specific evidence in a network environment can be a hard task. There are multiple sources of evidence commencing from the wireless access points to the web proxies to the central log servers which makes it often difficult to point out the exact location of an evidence. In certain cases, where we are still aware of specific evidence and as to where it resides, obtaining an access to it can often become complex at times due to the political or technical reasons.

Content: Apart from the filesystems, which are mainly designed to contain all the contents of files and their metadata, network devices may or may not store evidence with the level of granularity desired. The storage limit capacity of the network devices is often very limited. Most of the time, only the selected metadata about the data transfer or transaction is maintained as compared to entire records of the data that traversed the network.

Storage: Secondary or persistent storage are usually not engaged as part of network devices. As a result of this consequence a device may not be able to survive a reset because the data contained in these network devices are unstable and uncertain.

Privacy: Depending on the jurisdiction, legal issues could arise which may include personal privacy issues that are unique to network-based acquisition techniques.

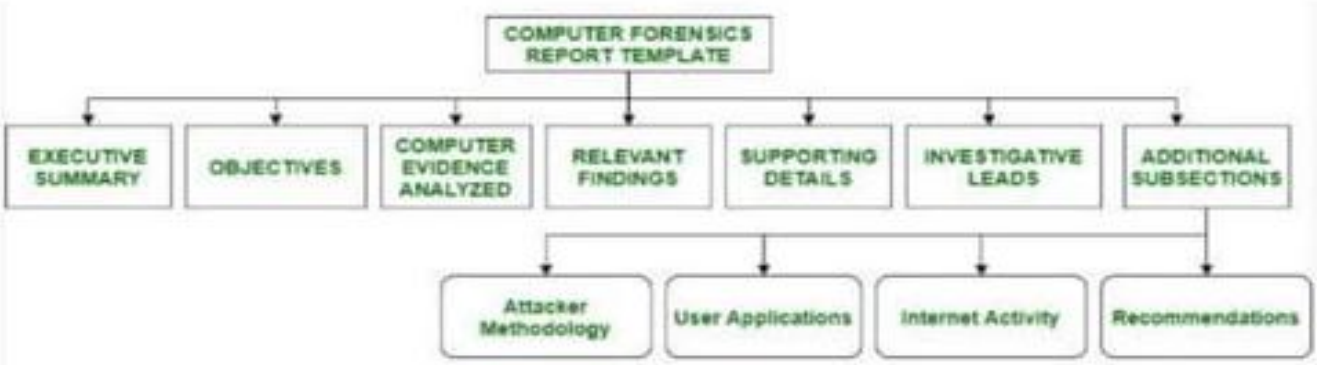
Seizure: Seizing of a hard drive can cause trouble and disruption to an individual or

organization. However, a copy of the original hard drive can be constructed and deployed where the grave operations can continue with limited disturbance. Seizure done to a network device are most often way more disruptive. In the most serious cases, an entire network segment may be brought down perpetually. In most of the circumstances, investigators have the ability to minimize the impact on network operations.

Admissibility: Filesystem-based evidence is being admitted consistently both in criminal and civil proceedings. As long as the filesystem-based evidence is relevant to the case, lawfully acquired & properly handle there is a clear precedent for validating or verifying the evidence and admitting it in court. In variance, the network forensics is one of the newest approaches to digital investigations. Often there arise conflicting or even non-existing legal precedents for the admission of various types of network-based digital evidence. With time the network-based digital evidence may become more widespread and the case precedents will be set and standardized.

Writing Computer Forensics Reports

The main goal of Computer forensics is to perform a structured investigation on a computing device to find out what happened or who was responsible for what happened, while maintaining a proper documented chain of evidence in a formal report. Syntax or template of a Computer Forensic Report is as follows:



1. **Executive Summary:**
   Executive Summary section of computer forensics report template provides background data of conditions that needs a requirement for investigation. Executive Summary or the Translation Summary is read by Senior Management as they do not read detailed report. This section must contain short description, details and important pointers. This section could be one page long. Executive Summary Section consists of following:
   - Taking account of who authorized the forensic examination.
   - List of the significant evidences in a short detail.
   - Explaining why a forensic examination of computing device was necessary.
   - Including a signature block for the examiners who performed the work.

- Full, legitimate and proper name of all people who are related or involved in case, Job Titles, dates of initial contacts or communications.

2. **Objectives:**
Objectives section is used to outline all tasks that an investigation has planned to complete. In some cases, it might happen that forensics examination may not do a full fledged investigation when reviewing contents of media. The prepared plan list must be discussed and approved by legal council, decision makers and client before any forensic analysis. This list should consist tasks undertaken and method undertaken by an examiner for each task and status of each task at the end of report.

3. **Computer Evidence Analyzed:**
The Computer Evidence Analyzed section is where all gathered evidences and its interpretations are introduced. It provides detailed information regarding assignment of evidence's tag numbers, description of evidence and media serial numbers.

4. **Relevant Findings:**
This section of Relevant Findings gives summary of evidences found of **probative Value** When a match is found between forensic science material recovered from a crime scene e.g., a fingerprint, a strand of hair, a shoe print, etc. and a reference sample provided by a suspect of case, match is widely considered as strong evidence that suspect is source of recovered material. However, probative value of evidence can vary widely depending on way in which evidence is characterized and hypothesis of its interest. It answers questions such as "What related objects or items were found during investigation of case?".

5. **Supporting Details:**
Supporting Details is section where in-depth analysis of relevant findings is done. 'How we found conclusions outlined in Relevant Findings?', is outlined by this section. It contains table of vital files with a full path name, results of string searches, Emails/URLs reviewed, number of files reviewed and any other relevant data. All tasks undertaken to meet objectives is outlined by this section. In Supporting Details we focus more on technical depth. It includes charts, tables and illustrations as it conveys much more than written texts. To meet outlined objectives, many subsections are also included. This section is longest section. It starts with giving background details of media analyzed. It is not easy to report number of files reviewed and size of hard drive in a human understandable language. Therefore, your client must know how much data you wanted to review to arrive at a conclusion.

6. **Investigative Leads:**
Investigative Leads performs action items that could help to discover additional information related to the investigation of case. The investigators perform all

outstanding tasks to find extra information if more time is left. Investigative Lead section is very critical to law enforcement. This section suggests extra tasks that discovers information needed to move on case. e.g. finding out if there are any firewall logs that date any far enough into past to give a correct picture of any attacks that might have taken place. This section is important for a hired forensic consultant.

7. **Additional Subsections:**
   Various additional subsections are included in a forensic report. These subsections are dependent on clients want and their need. The following subsections are useful in specific cases :
   - **Attacker Methodology –**
     Additional briefing to help reader understand general or exact attacks performed is given in this section of attacker methodology. This section is useful in computer intrusion cases. Inspection of how attacks are done and what bits and pieces of attacks look like in standard logs is done here.
   - **User Applications –**
     In this section we discuss relevant applications that are installed on media analyzed because it is observed that in many cases applications present on system are very relevant. Give a title to this section, if you are investigating any system that is used by an attacker .e.g Cyber Attack Tools.
   - **Internet Activity –**
     Internet Activity or Web Browsing History section gives web surfing history of user of media analyzed. The browsing history is also useful to suggest intent, downloading of malicious tools, unallocated space, online researches, downloading of secure deleted programs or evidence removal type programs that wipe files slack and temporary files that often harbor evidence very important to an investigation.
   - **Recommendations –**
     This section gives recommendation to posture client to be more prepared and trained for next computer security incident. We investigate some host-based, network-based and procedural countermeasures are given to clients to reduce or eliminate risk of incident security.

AUDITING

Forensic auditing has taken an important role in both private andpublic organizations since the dawn of the 21st century especiallyin the advance economies. The failure of some formerly prominentpublic companies such as Enron and WorldCom (MCI Inc.) in thelate 1990s, coupled with the terrorist attacks of September 11,2001, fueled the prominence of forensic auditing/ accounting,creating a new, important and lucrative specialty. Forensicauditing procedures target mostly financial and operational fraud, discovery of hidden assets, and adherence to federal regulations. In forensic auditing specific procedures are carried out in order to produce evidence. Audit techniques and procedures are used to identify and to gather evidence to prove, for example, how long have fraudulent activities existed and carried out in the organization, and how it was conducted and concealed by the perpetrators. Evidence may also be gathered

to support other issues which would be relevant in the event of a court case.

Forensic Audit Thinking- in other words—thinking forensically

Forensic Audit Procedures — both proactive and reactive

Appropriate use of technology and data analysis

Involves the critical assessment throughout the audit of all evidential matter and maintaining a higher degree of professional skepticism that for example fraud or financial irregularity may have occurred, is occurring, or will occur in the future. Furthermore Forensic thinking is a mind shift where the auditor believes that the possibility offraud or financial irregularity may exist and the controls may be overridden to accomplish that possibility. Forensic thinking is used through outthe audit work i.e. from start to finish.

FORENSIC AUDIT PROCESS

Forensic audit procedures are more specific and geared toward detecting the possible material misstatements in financial statements resulting from fraudulent activities or error. Audit procedures should align with Fraud Risks and Fraud Risk Assessments. According to Donald R. Cressy, in his proposition—"Fraud Trianglel" he highlighted that there are three interrelated elements that enable someone to commit fraud: the Motive that drives a person to want to commit the fraud, the Opportunity that enables him to commit the fraud, and the ability to Rationalise the fraudulent behaviour. The vulnerability that an organisation has to those capable of overcoming all three elements of the fraud triangle is fraud risk. Fraud risk can come from sources both internal and external to the organisation.



Information Security Management System (ISMS)

Information security management describes the set of policies and procedural controls that IT and business organizations implement to secure their informational assets against threats and vulnerabilities. Responsibility for information security may be assigned to a Chief Security Officer, Chief Technical Officer, or to an IT Operations manager whose team includes IT operators and security analysts. Many organizations develop a formal, documented process for managing InfoSec - often called an Information Security Management System, or ISMS.
An information security management system (ISMS) is a framework of policies and controls that manage security and risks systematically and across your entire enterprise—information security. These security controls can follow common security standards or be more focused on your industry.



ISMS is designed to establish holistic information security management capabilities; digital transformation requires organizations to adopt ongoing improvements and evolution of their security policies and controls.

The structure and boundaries defined by an ISMS may apply only for a limited time frame and the workforce may struggle to adopt them in the initial stages. The challenge for organizations is to evolve these security control mechanisms as their risks, culture, and resources change.

Introduction to ISO 27001:2013
It is the international standard for information security. It sets out the specification for an information security management system (ISMS). The information security management system standard's best-practice approach helps organisations manage their information security by addressing people, processes and technology. Certification to the ISO 27001 Standard is recognised worldwide as an indication that your ISMS is aligned with information security best practice.

Part of the ISO 27000 series of information security standards, ISO 27001 is a framework that helps organisations "establish, implement, operate, monitor, review, maintain and continually improve an ISMS".
An ISMS is a holistic approach to securing the confidentiality, integrity and availability (CIA) of corporate information assets.

It consists of policies, procedures and other controls involving people, processes and technology.

Informed by regular information security risk assessments, an ISMS is an efficient, risk-based and technology-neutral approach to keeping your information assets secure.

According to ISO 27001, ISMS implementation follows a Plan-Do-Check-Act (PCDA) model for continuous improvement in ISM processes:

Plan. Identify the problems and collect useful information to evaluate security risk. Define the policies and processes that can be used to address problem root causes. Develop methods to establish continuous improvement in information security management capabilities.
Do. Implement the devised security policies and procedures. The implementation follows the ISO standards, but actual implementation is based on the resources available to your company.
Check. Monitor the effectiveness of ISMS policies and controls. Evaluate tangible outcomes as well as behavioral aspects associated with the ISM processes.
Act. Focus on continuous improvement. Document the results, share knowledge, and use a feedback loop to address future iterations of the PCDA model implementation of ISMS policies and controls.